part of every system we build. Every digital identity system has ways to recognize, remember, and relate to the entities using it.

Authenticating is how the system *recognizes*. Authentication (sometimes abbreviated as *authn*) is the process of determining whether the entity making a request is really the one it claims to be. The process of authentication can be complicated, and many security problems stem from failures in authentication. The Target story at the beginning of this chapter, for example, started with a failure of authentication. The hackers were able to impersonate the contractor, fooling the system into recognizing them as legitimate users.

Accounts are where identity systems *remember*. Every identity system has a database or directory that keeps track of information about the entities it has formed relationships with. This information includes functional items, like user IDs, passwords, and keys, as well as other attributes the system might need, like names, addresses, credit card numbers, preferences, and so on.

Authorizing actions is one of the primary ways identity systems *react* to requests. Authorization (sometimes abbreviated as *authz*) is the process by which we control access to computer systems and is the natural complement to authentication, where authentication determines “who,” authorization determines “what.”

Every application, whether it runs in the cloud or is connected to it, has access management challenges. As multi-tenanted applications have become the norm, authentication is rarely sufficient to establish which actions a user can perform on which resources. Traditionally, applications have dealt with these issues using tools like access control lists (ACLs) or user and group permissions. But most applications need more fine-grained access control than ACLs or groups can provide. Often, what access control logic exists beyond these lists is embedded in the code or, worse, in stored procedures in the database.